

How to tune the ECAS Client redirection mechanism

The redirection code is performed by the *eu.cec.digit.ecas.client.http.HttpRedirector* interface

Below is the default redirection code,

```
/**
 * Performs redirections using HTTP 302 (for HTTP/1.0 users)
 * and HTTP 303 (for HTTP/1.1 users) and uses the passed redirectionUrl
 * String as Location value.
 *
 * @param request the current request
 * @param response the current response
 * @param redirectionUrl the location where the user is to be redirected to
 * for the ECAS login.
 *
 * @throws IOException if an I/O exception occurs.
 * @throws ServletException if a ServletException occurs.
 */
public void engineSendRedirect(HttpServletRequest request,
                              HttpServletResponse response,
                              String redirectionUrl) throws IOException,
                              ServletException {
    int code;
    if ("HTTP/1.1".equals(request.getProtocol())) {
        code = HttpServletResponse.SC_SEE_OTHER;
    } else {
        code = HttpServletResponse.SC_MOVED_TEMPORARILY;
    }
    response.setStatus(code, "ECAS Authentication Required");
    response.setHeader("Location", redirectionUrl);

    response.setHeader("Pragma", "no-cache");
    response.setHeader("Cache-Control", "no-cache,no-store,no-transform");
    response.setDateHeader("Expires", -1);

    String contentSecurityPolicy = "default-src 'none'; reflected-xss
'block'";
    response.setHeader("X-Webkit-CSP", contentSecurityPolicy);
    response.setHeader("X-Content-Security-Policy", contentSecurityPolicy);
    response.setHeader("Content-Security-Policy", contentSecurityPolicy);

    response.setHeader("X-XSS-Protection", "1; mode=block");
    response.setHeader("X-Content-Type-Options", "nosniff");

    // Enrich the response, e.g. to prevent indexation of ECAS by search
    engines:
    List/*<RedirectionInterceptor>*/ redirectionInterceptors =
configuration.getRedirectionInterceptors();
    for (int i = 0, n = redirectionInterceptors.size(); i < n; i++) {
        RedirectionInterceptor redirectionInterceptor =
```

```

(RedirectionInterceptor) redirectionInterceptors.get(i);
    redirectionInterceptor.enrichResponseOnRedirection(request,
response);
    if (response.isCommitted()) {
        throw new ServletException(
            "Bad RedirectionInterceptor prevented redirection to
the ECAS Server by committing the response: \""
                + redirectionInterceptor.getClass().getName()
+ "\"");
    }
}

    response.setContentType("text/html; charset=" + DEFAULT_ENCODING.
toLowerCase(Locale.ENGLISH));

    response.getWriter().write(new StringBuffer()

.append("<html><head><title>").append(code).append(" -
Redirecting To ECAS</title></head>").append(HTTP_CRLF)
.append("<body bgcolor=\"#FFFFFF\">").append(HTTP_CRLF)
.append("<p>This document you requested requires ECAS
Authentication.</p>").append(HTTP_CRLF)

.append("<p>You may authenticate to access this document at <a
href=\"").append(redirectionUrl).append("\>")
.append(redirectionUrl).append("</a>.</p>").append(HTTP_CRLF)
.append("</body></html>").toString());
    response.flushBuffer();
}

```

As you can see, the code uses the non-ambiguous HTTP 303 status code for HTTP/1.1 and only uses HTTP 302 for HTTP/1.0.

You are free to plug in your own implementation of the `HttpRedirector` interface suiting your specific needs.

The configuration property is:

```
#####
## httpRedirector
### The implementation of HttpRedirector to use to redirect to the ECAS
Server login URL.
### [Optional]
### [DefaultValue=eu.cec.digit.ecas.client.http.DefaultHttpRedirector]
### ProvidedImplementations:
eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.DefaultHttpRedirector
#eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.BrowserPostRedirector
#eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.LegacyHttpRedirector
#eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.ajax.JsonHttpRedirector
#eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.JavascriptHttpRedirector
#eu.cec.digit.ecas.client.filter.httpRedirector=eu.cec.digit.ecas.client.
http.LegacyJavascriptHttpRedirector
#####
```

And the interface to implement is

```
package eu.cec.digit.ecas.client.http;
...

/**
 * The strategy that handles the redirection mechanism to perform HTTP
 * redirections
 * to the ECAS server login screen.
 *
 */
public interface HttpRedirector {
...

    /**
     * Redirects to ECAS Server login screen (e&#x2E;g&#x2E; HTTP 302).
     * Can be used to force a renew, a gateway mode or strength level.
     *
     *
     */
    void sendRedirect(HttpServletRequest request,
                     HttpServletResponse response,
                     LoginParameters loginParameters) throws IOException,
                     ServletException;
}
```

And the simplest way to implement this interface is to extend *eu.cec.digit.ecas.client.http.LocationBasedHttpRedirector* as is done in the *eu.cec.digit.ecas.client.http.DefaultHttpRedirector*

Out of the box, switching to Browser POST (*eu.cec.digit.ecas.client.http.BrowserPostRedirector*) would use a javascript to POST the request to the EU Login server instead of a redirect.

So this returns an HTTP 200 instead of an HTTP 303/302.

The drawback is that javascript is required.